

Software Requirements Specification (SRS)

Sikkim Tourism Assistant

AI-Powered Visitor Information System

Prepared for:

Tourism & Civil Aviation Department
Government of Sikkim

Prepared by:

Team Nexus — Four-Developer Internship Team
ICFAI University Sikkim
Third-Year Students

Document version: 1.1

Date: 13 August 2026

Project status: Deployed implementation / Department handover

Interactive submission version: [Open the professional HTML SRS](#)

Standalone database ER diagram: [Open/download the SVG ER diagram](#)

Document Control

Item	Details
Document title	Software Requirements Specification — Sikkim Tourism Assistant
Intended audience	Tourism & Civil Aviation Department, Government of Sikkim; technical reviewers; project evaluators; deployment administrators
Prepared by	Team Nexus, ICFAI University Sikkim
Review status	Department handover candidate
Classification	Departmental project documentation

Revision History

Version	Date	Description
1.0	9 August 2026	Initial submission-ready SRS
1.1	13 August 2026	Security hardening, deployment handover, verification, and final interface documentation updated

Executive Summary

The Sikkim Tourism Assistant is a web-based, AI-assisted visitor information system designed for the Tourism & Civil Aviation Department, Government of Sikkim. It provides visitors with practical and trustworthy guidance about destinations, permits, routes, travel seasons, official notices, and registered travel agencies.

Unlike a general-purpose chatbot, the system is designed to ground relevant answers in Department-managed destination records, official circulars, and registered travel-agency data. It also provides a protected administrative console through which authorised Department personnel can maintain destination information, ingest official notices, manage circulars, and synchronise approved data sources.

The system has been designed with security, traceability, and practical deployment in mind. It uses a React/Vite visitor interface, a FastAPI backend, MySQL for persistent records, and retrieval-augmented generation (RAG) for AI-assisted answers. Time-sensitive public notices are displayed with their issue date, and the assistant is instructed not to invent official facts when verified information is unavailable.

1. Introduction

1.1 Purpose

This Software Requirements Specification defines the functional, non-functional, security, operational, and acceptance requirements for the Sikkim Tourism Assistant. It serves as the reference document for Department review, internship evaluation, future maintenance, and production deployment planning.

1.2 Scope

The system shall support the following public services:

- browsing and searching the Department destination catalogue;
- asking tourism-related questions through a streaming AI chat interface;
- receiving guidance on permits, routes, seasons, travel preparation, culture, and destinations;
- viewing recent official travel advisories and notices with issue dates;
- requesting practical, day-wise trip-planning assistance; and
- asking about registered travel agencies from the official directory.

The system shall support the following administrative services:

- first-time administrator setup using a server-side bootstrap secret;
- password-based administrator authentication;
- destination creation, editing, previewing, and deletion;
- circular upload, listing, deletion, and synchronisation;
- approved travel-agency directory synchronisation; and
- vector-store re-indexing after source-data changes.

1.3 Out of Scope

The following are not part of the current scope:

- online payments, bookings, hotel reservations, or ticketing;
- replacing official permit-issuing workflows;
- collecting visitor identity documents or payment-card data;
- making emergency decisions or issuing legal/medical advice;
- publishing unverified social-media content as an official notice; and
- unrestricted web crawling or open-ended internet search.

1.4 Definitions

Term	Meaning
RAG	Retrieval-Augmented Generation: AI answers are grounded using relevant retrieved records.
Circular	An official notice, road-status report, cancellation order, or advisory.
OCR	Optical Character Recognition used to extract text from uploaded PDFs or images.
SSE	Server-Sent Events used to stream AI answer text to the browser.
Qdrant	Vector database/search component used for semantic retrieval.
Administrator	A Department-authorised user permitted to manage protected system data.

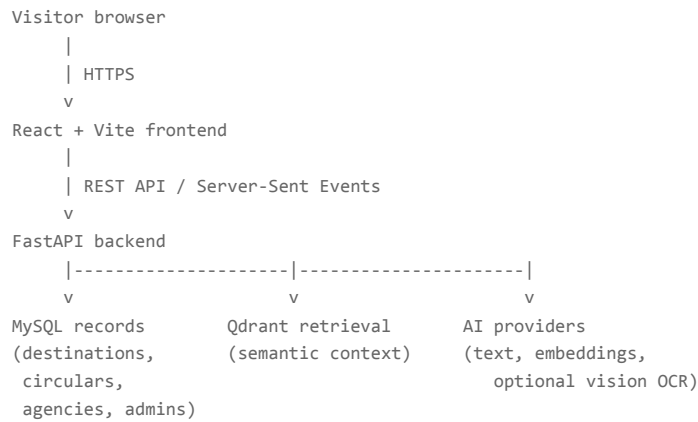
2. Stakeholders and Users

Stakeholder	Interest / Responsibility
Tourism & Civil Aviation Department, Government of Sikkim	System owner, approval authority, authoritative data provider.
Department administrators	Maintain destinations, circulars, and approved data through the admin console.
Domestic and international visitors	Use the public site for travel information and assistance.
Registered travel agencies	Indirect beneficiaries of accurate directory representation.
Team Nexus, ICFAI University Sikkim	Internship development team and initial technical documentation authors.
Hosting / infrastructure administrator	Configures deployment, secrets, domains, backups, monitoring, and network controls

3. Product Overview

3.1 Product Perspective

The Sikkim Tourism Assistant is a standalone visitor-information application with a browser frontend and an API backend. It uses Department-controlled records as its principal source of structured tourism information.



3.2 Design Principles

- **Official-data first:** structured Department records take priority over generic AI knowledge.
- **Safety over confidence:** the assistant shall state when verified official information is unavailable rather than inventing it.
- **Least privilege:** public visitors receive only public data; administrative actions require authentication.
- **Privacy by design:** no visitor login is required for public use; administrator passwords are not stored in frontend local storage.
- **Progressive enhancement:** public destination browsing remains useful even if an advisory feed or AI service is temporarily unavailable.

4. Functional Requirements

4.1 Public Destination Catalogue

ID	Requirement
FR-01	The system shall display Department-managed destination records to public visitors.
FR-02	The system shall allow visitors to search destinations by text.
FR-03	The system shall allow visitors to filter destinations by approved category.
FR-04	The system shall display destination details including description, district, best time to visit, permits, travel guidance, highlights, and image

ID	Requirement
FR-05	The system shall display local image paths only for administrator-managed destination imagery.
FR-06	The system may show current weather where geographic coordinates are available.

4.2 AI Tourism Assistant

ID	Requirement
FR-07	The system shall provide a public conversational interface for Sikkim tourism questions.
FR-08	The system shall stream generated responses to the visitor interface using SSE.
FR-09	The assistant shall prioritise relevant retrieved Department data when answering destination, circular, or travel-agency questions.
FR-10	The assistant shall decline unrelated requests and redirect users to Sikkim tourism assistance.
FR-11	The assistant shall avoid inventing permit rules, road status, agency contacts, prices, or official notices.
FR-12	The assistant shall support concise answers in the visitor's language where reasonably supported by the configured AI model.
FR-13	The assistant shall provide practical day-wise itinerary guidance when asked to plan a trip, while clearly marking details that depend on cur
FR-14	The system shall provide suggested visitor prompts, including permit, route, culture, and trip-planning prompts.

4.3 Image-Assisted Queries

ID	Requirement
FR-15	The system shall allow a visitor to attach JPEG, PNG, or WebP images to a chat request.
FR-16	The backend shall validate the image MIME type, base64 encoding, file signature, and size before forwarding it to an AI provider.
FR-17	The system shall not persist raw visitor image bytes in the conversation database.

4.4 Official Advisories and Circulars

ID	Requirement
FR-18	The public homepage shall show recent official travel advisories when records are available.
FR-19	Each public advisory shall show its title, category, issue date, and district when applicable.
FR-20	Public advisory links shall be rendered only for approved HTTPS URLs on the official tourism domain.
FR-21	The public advisory feed shall not expose OCR text, file hashes, internal ingestion metadata, or administrative-only fields.
FR-22	The assistant shall state the issue date when answering from a circular or road-status record.

4.5 Registered Travel Agencies

ID	Requirement
FR-23	The assistant shall use the official registered-agency directory for agency registration, contact, or address queries.
FR-24	The system shall answer high-risk single-agency detail requests from verified directory data rather than allowing the language model to inv
FR-25	The system shall ask the visitor for clarification if multiple agency records may match a query.

4.6 Conversation Handling

ID	Requirement
FR-26	The system shall create an anonymous conversation identifier for a new visitor chat session.

ID	Requirement
FR-27	The system shall validate conversation identifiers before use.
FR-28	The system shall support idempotent chat retries using a client message identifier, preventing duplicate model charges and duplicate store
FR-29	Conversation responses shall be marked non-cacheable.

4.7 Administrator Functions

ID	Requirement
FR-30	The system shall permit creation of the first administrator account only with a configured bootstrap secret.
FR-31	The system shall require valid administrator credentials for protected administrative actions.
FR-32	Administrators shall be able to create, edit, preview, and delete destination records.
FR-33	Administrators shall be able to upload approved PDF, JPEG, PNG, or WebP circular files.
FR-34	The system shall reject circular uploads that exceed configured limits, are empty, or do not carry a recognised PDF/image signature.
FR-35	Administrators shall be able to synchronise approved circular and travel-agency sources.
FR-36	Administrators shall be able to re-index the vector store after data changes.
FR-37	Administrators shall be able to change their username and password after re-authentication.

5. Non-Functional Requirements

5.1 Security Requirements

ID	Requirement
NFR-01	Production deployments shall use HTTPS.
NFR-02	Production CORS configuration shall use explicit HTTPS origins; wildcard origins shall be rejected.
NFR-03	Administrator passwords shall be stored only as salted script hashes.
NFR-04	Authentication and setup secrets shall be supplied through environment variables and shall not be committed to source control.
NFR-05	Administrative endpoints shall require authentication and be rate-limited.
NFR-06	The application shall apply <code>nosniff</code> , anti-framing, referrer, permissions, and content-security-policy headers.
NFR-07	Uploaded circular files shall be size-limited and signature-validated.
NFR-08	The official circular scraper shall be restricted to the approved <code>sikkimtourism.gov.in</code> HTTPS host.
NFR-09	User input shall be length-limited and validated before use.
NFR-10	Public errors shall not disclose internal exception details or credentials.
NFR-10a	Remote MySQL connections shall validate both the configured certificate authority and the server certificate identity.
NFR-10b	Chat and upload request bodies shall be bounded before JSON or multipart parsing.
NFR-10c	Production bootstrap secrets shall meet the configured 32-character minimum.
NFR-10d	Retrieved, OCR, and live-web content shall be treated as untrusted data and shall not be allowed to override system instructions.

5.2 Performance Requirements

ID	Requirement
NFR-11	Public destination list responses should normally complete within 2 seconds under normal network and database conditions.

ID	Requirement
NFR-12	The first streamed AI response chunk should be returned as quickly as provider and retrieval services permit.
NFR-13	The frontend shall use route-level code splitting to limit unnecessary initial downloads.
NFR-14	Destination records may be cached publicly for a short controlled period; conversation and admin responses shall not be cached.

5.3 Reliability and Availability Requirements

ID	Requirement
NFR-15	Failure to populate the vector store at startup shall not prevent the core API from starting.
NFR-16	Optional scraper failures shall be logged and shall not terminate the web service.
NFR-17	The system shall return stable, user-safe errors for unexpected backend failures.
NFR-18	Database backups shall be scheduled and tested by the deployment administrator before production launch.

5.4 Usability and Accessibility Requirements

ID	Requirement
NFR-19	The public interface shall be responsive across mobile, tablet, and desktop screen sizes.
NFR-20	Interactive controls shall support keyboard use and meaningful labels.
NFR-21	Status information such as advisory dates shall be shown in clear, human-readable language.
NFR-22	The assistant shall use a professional, helpful, tourism-focused tone and shall remain emoji-free by default for official credibility.

6. Data Requirements

6.1 Core Data Entities

Entity	Purpose	Examples of Key Fields
Destinations	Department destination catalogue	name, category, district, description, permit requirement, route guidance, coordina
Circulars	Official notices and road-status information	title, category, issue date, district, source URL, extracted text, hash
Travel agencies	Registered-agency directory	name, registration number, district, proprietor, contact, address
Admin users	Protected administrator accounts	username, password hash
Conversations	Visitor chat session container	UUID, created time
Messages	Conversation turns	UUID, conversation UUID, role, content, client message ID

6.2 Data Quality Rules

- Destination categories shall be limited to approved values.
- Destination image URLs shall be limited to local /images/ paths.
- Circular categories shall be limited to road status, cancellation order, or notice.
- Circular uploads shall be deduplicated by SHA-256 file hash.
- Agency records shall be keyed by registration number.
- District aliases shall be normalised for reliable directory and destination queries.
- Administrator usernames shall use a restricted safe-character format.

6.3 Data Retention and Privacy

- The project does not require visitor registration for public chat use.
- Raw images attached to chat messages shall not be stored in the conversation database.
- Conversation retention duration shall be determined by the Department before production deployment.
- Administrator credentials shall never be stored in browser local storage.
- Database backups and access logs shall be retained according to Department policy.

7. External Interfaces

7.1 User Interface

The public interface shall include:

- a homepage with Department branding, travel highlights, official advisories, and entry points to destinations and chat;
- a destination catalogue with search, category filtering, cards, and detailed dialogs;
- a chat widget with streamed responses, conversation recovery, image attachment, and suggested prompts; and
- an administrator console for authenticated Department personnel.

7.2 API Interface

Representative public endpoints include:

Endpoint	Method	Purpose
/api/health	GET	Service health information.
/api/destinations	GET	Public destination catalogue.
/api/destinations/categories	GET	Supported public destination categories.
/api/destinations/advisories	GET	Minimal public official-advisory feed.
/api/conversations	POST	Create an anonymous conversation.
/api/conversations/{id}	GET	Retrieve a conversation.
/api/conversations/{id}/chat	POST	Send a message and receive SSE-streamed answer text.

Administrative endpoints are intentionally protected and shall not be used without valid credentials.

7.3 Third-Party Services

Service Type	Intended Use	Operational Note
MySQL	Persistent system records	Required for production data.
Qdrant	Semantic retrieval/vector search	May be local or remote according to deployment configuration.
Gemini	Embeddings and optional image/OCR support	Requires an API key.
Groq	Text generation and optional prompt guard	Requires an API key.
Open-Meteo	Optional current weather display	Public weather service; no API key required by the application.

8. Security Architecture and Controls

8.1 Authentication and Authorisation

- First-admin setup requires the server-side `ADMIN_API_KEY` bootstrap secret.
- Subsequent admin actions require HTTP Basic authentication over HTTPS.
- Passwords are salted and hashed using `bcrypt`.

- Admin operations are rate-limited to reduce password-guessing and costly authentication attempts.
- Login verification performs equivalent password-hash work for unknown users to reduce username-enumeration timing signals.
- The bootstrap secret must be generated securely and rotated if exposed.
- In production, the bootstrap secret must be at least 32 characters long.

8.2 Browser Protections

- Content Security Policy is applied to limit executable and external content.
- X-Frame-Options: DENY prevents embedding in hostile frames.
- X-Content-Type-Options: nosniff reduces browser MIME confusion.
- A restrictive referrer policy reduces unnecessary URL leakage.
- HSTS is enabled in production.

8.3 Input and Upload Protection

- API models enforce field lengths, formats, and permitted values.
- Image chat payloads are size-limited and validated against their byte signatures.
- Circular uploads are checked before OCR processing and limited in size.
- Uploaded circular images and PDFs must carry recognised file signatures; client-provided MIME labels alone are not trusted.
- Chat and upload requests are rejected when their declared or streamed body exceeds the configured server limit.
- Destination imagery is restricted to local public image paths to avoid untrusted remote URL injection.

8.4 AI Safety Controls

- Retrieved documents, OCR output, live web content, images, and conversation history are treated as reference data, not instructions.
- Instruction-like prompt-injection text is removed from untrusted retrieved context before it is supplied to the answer model.
- Official agency contacts, registration numbers, and road-status facts are handled from verified database context rather than AI guesswork.
- Current circular data includes issue dates so visitors can assess timeliness.
- When official information is unavailable, the assistant shall state this clearly.

9. Deployment Requirements

9.1 Recommended Topology

The recommended deployment topology is a frontend deployment platform for the React application and a managed application platform for the FastAPI backend, with managed MySQL and optional managed Qdrant.

9.2 Required Production Configuration

At minimum, the production administrator shall configure:

```
ENVIRONMENT=production
ALLOWED_ORIGINS=https://<official-frontend-domain>
MYSQL_HOST=<managed-mysql-host>
MYSQL_USER=<database-user>
MYSQL_PASSWORD=<strong-secret>
MYSQL_DATABASE=sikkim_tourism
GEMINI_API_KEY=<secret>
GROQ_API_KEY=<secret>
ADMIN_API_KEY=<at-least-32-character-bootstrap-secret>
```

9.3 Deployment Checklist

- ☐ Configure the official frontend domain and production CORS origin.
- ☐ Provision MySQL and apply `docs/schema.sql` plus required migrations.
- ☐ Store all secrets in the hosting platform's secret manager/environment configuration.

- ☐ Confirm remote MySQL TLS/CA configuration.
- ☐ Configure database backups and restoration testing.
- ☐ Place the backend behind HTTPS, a reverse proxy/WAF, and a request-size limit.
- ☐ Use a WAF or shared/distributed rate limiter before operating more than one backend instance.
- ☐ Set restrictive outbound network controls for optional scraping.
- ☐ Create the first administrator account using a securely generated bootstrap secret.
- ☐ Remove or rotate the bootstrap secret after initial setup according to Department policy.
- ☐ Validate public advisories, destination management, admin authentication, and chat workflows after deployment.

10. Testing and Quality Assurance

10.1 Completed Verification

At the time of this document version, the project verification included:

Check	Result
Backend automated tests	68 tests passed
Frontend production build	Passed using TypeScript and Vite build process
JavaScript production dependency audit	No known advisories reported for the deployment lockfile at the last audit
Python dependency audit	No known advisories reported for requirements.txt at the last audit
Security regression tests	Auth failure, public rate limits, SSRF allow-list rejection, malformed input, request-size limits, and RAG c

10.2 Recommended User Acceptance Testing

Before public launch, the Department should conduct acceptance testing with representative questions:

1. Search and open several destinations from each category.
2. Ask about permits for Nathula Pass and restricted areas.
3. Ask for a three-day Sikkim itinerary.
4. Ask a question in Hindi and verify a useful response.
5. Upload an authorised sample road-status circular as an administrator.
6. Confirm that the public advisory feed shows correct title, date, district, and official source.
7. Confirm that incorrect admin credentials are rejected.
8. Confirm that an invalid upload, oversized file, or spoofed file type is rejected.
9. Confirm that road-status answers cite the available report date and do not invent missing status information.
10. Verify the website on current Android, iOS, desktop Chrome, Firefox, and Edge browsers.

11. Risks, Assumptions, and Mitigations

Risk / Assumption	Impact	Mitigation
Official data may become outdated	Visitors may receive stale travel guidance	Establish Department ownership and a regular circular/desti
AI provider outage or quota limitation	Chat responses may be delayed/unavailable	Preserve public destination browsing; show safe error mess
Road status changes quickly	Incorrect travel decisions could occur	Show issue dates; direct visitors to confirm critical same-da
Incorrect admin configuration	Security or availability risk	Use deployment checklist, restricted CORS, secret manage
Unauthorised use of admin access	Data integrity risk	Strong passwords, rate limits, least privilege, bootstrap-sec
Malicious uploaded file	Processing or storage risk	Enforce request size, file signatures, authenticated upload, a

12. Future Enhancements

The following enhancements are recommended for a future approved phase:

- Department-reviewed multilingual interface labels and curated Hindi/Nepali content;
- shareable and printable itinerary summaries;
- itinerary saving only with an explicit privacy notice and retention policy;
- live official road-status dashboard with staff approval workflow;
- accessibility audit against WCAG 2.2 AA;
- administrator audit-log interface;
- structured analytics using privacy-preserving, consent-aware metrics;
- integration with official permit and booking portals through approved APIs; and
- disaster recovery drills and operational monitoring dashboards.

13. Department Handover and Operational Ownership

This repository is delivered as a deployed implementation and technical handover. The Department becomes the operational owner when it integrates the service with the official domain.

13.1 Handover package

The handover package shall include this SRS, the project README, source code, database schema and migrations, environment-variable template, deployment configuration, automated tests, and the current deployment URLs. Production secrets shall be transferred only through an approved secret-management process, never through source control, email attachments, or public documents.

13.2 Department-controlled actions

Before public release, the Department shall:

1. set `ALLOWED_ORIGINS` to the exact final HTTPS origin under `sikkimtourism.gov.in` (or the Department-approved official frontend host);
2. control DNS, custom-domain configuration, certificates, Railway/Vercel access, production secrets, backups, and restoration testing;
3. nominate administrators and establish MFA/SSO, credential rotation, and administrator off-boarding procedures;
4. adopt a privacy notice, conversation-retention schedule, content-review workflow, incident-response process, and accessibility acceptance process;
5. deploy WAF/DDoS controls and distributed rate limiting where the backend is scaled beyond one instance; and
6. obtain independent security testing and formal approval before public use.

13.3 Operational limitation

The application-level limiter is suitable for an individual backend process. It is not a replacement for an edge/WAF or shared rate-limit store when multiple Railway instances are active. This is an infrastructure decision for the Department's deployment team.

14. Acceptance Criteria

The project shall be considered ready for Department-controlled deployment when:

1. The Department approves the content, branding, data governance process, and hosting environment.
2. All required production secrets and explicit HTTPS CORS origins are configured.
3. MySQL schema and migrations are applied successfully.
4. A Department administrator creates and verifies an administrator account.
5. Public destination browsing, chat, advisories, and protected admin workflows are successfully user-accepted.
6. Current automated tests and frontend build checks pass in the deployment candidate.
7. Database backup, restoration, and incident-contact procedures are documented by the operating team.
8. The Department confirms ownership for reviewing and updating official source data.

15. Declaration

This document describes the Sikkim Tourism Assistant developed as an internship project by **Team Nexus**, a four-developer team of **third-year students of ICFAI University Sikkim**. The project is respectfully submitted for review by the Tourism & Civil Aviation Department, Government of Sikkim.

Prepared By

Team Nexus

Four-Developer Internship Team

ICFAI University Sikkim

Third-Year Students

For Review By

Tourism & Civil Aviation Department

Government of Sikkim

End of document.